

Phishing - Endereço de email falso, rastreamento por pixels e mascaramento de destino

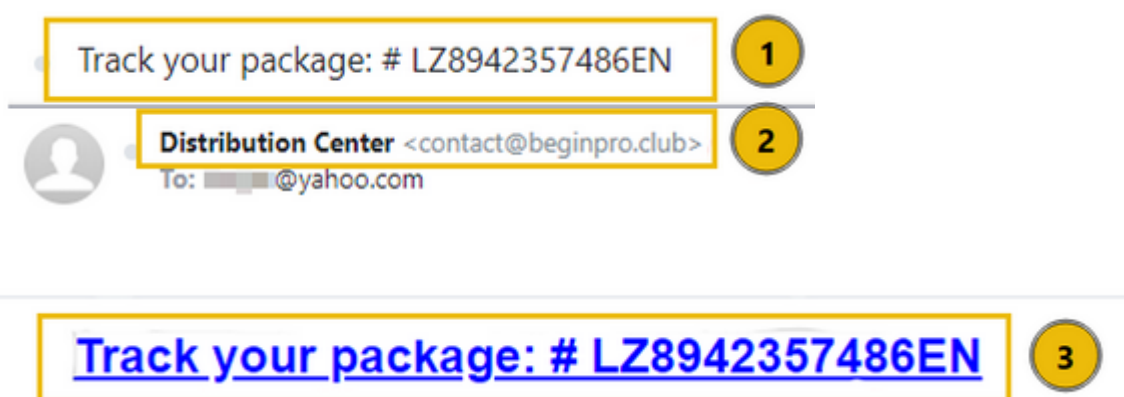
Irei analisar um email que simula uma notificação formal de envio para enganar os destinatários e criar uma sensação de urgência. Ao analisar esta amostra, foi descoberto como os atacantes usam endereços falsificados, manipulação de links e pixels de rastreamento para comprometer os usuários. Também irei examinar o código-fonte bruto para entender por que os provedores de e-mail sinalizaram esses problemas específicos.

Técnicas phishing utilizadas

- Endereço de e-mail falsificado: Simulação de um centro de distribuição confiável para obter credibilidade imediata
- Rastreamento por pixel: Imagens invisíveis para notificar o remetente quando o e-mail é aberto
- Manipulação de links: Mascaramento de um destino malicioso com um número de rastreamento fraudulento

Primeiras Observações

Ao analisar o e-mail abaixo destacar as observações iniciais.



- Assunto: O assunto usa um número de rastreamento falso para criar uma sensação de urgência, incentivando o destinatário a clicar para ver o status do pacote.

- Endereço do remetente: Isso é um sinal de alerta imediato, pois o nome de exibição "Centro de Distribuição" não corresponde ao endereço real do remetente: `contact@beginpro.club`
- Hiperlink: O link no corpo do e-mail corresponde ao assunto, embora ainda eu não saiba para onde ele direciona.

Neste exemplo de e-mail, o Yahoo bloqueou o carregamento automático das imagens. Normalmente, podemos passar o cursor sobre um link para ver para onde ele aponta, mas, neste exemplo, essa técnica não funciona porque o Yahoo desativou os links no e-mail. Irei então analisar o código-fonte do e-mail para descobrir.

Rastreamento de Hiperlinks

Analisando o código-fonte da mensagem de e-mail posso observar mais de perto o hiperlink com o número de rastreamento mencionado acima. Aqui está um arquivo de imagem chamado `Tracking.png`. Esses rastreadores enviam informações de volta para o servidor do spammer. Existem vários motivos pelos quais os spammers incorporam pixels de rastreamento (imagens muito pequenas) em seus e-mails, e agora podemos entender por que o Yahoo bloqueou automaticamente as imagens neste e-mail. Muitos provedores de e-mail fazem o mesmo.

Hyperlink Destination

```
=["http://devret.xyz/4833mt11254939vf6888zq22032si1269du1508rr" >  
ace=Rockwell> <FONT color="#0000FF" face="arial" size=5 ><strong>
```

```
<br/>
```

Tracking Pixel

```
=["http://devret.xyz/Creatives/Tracking.png"  
e="grmk"><br />
```

Display Text

Track your package: # LZ8942357486EN

Conclusão

Nessa análise foi possível identificar diversas técnicas clássicas de phishing utilizadas para manipular o destinatário e aumentar as chances de comprometimento. O atacante explorou engenharia social por meio de um falso aviso de entrega, criando urgência e curiosidade para induzir o clique da vítima. Além disso, a discrepância entre o nome exibido do remetente e o domínio real do e-mail demonstrou claramente uma tentativa de falsificação de identidade para transmitir credibilidade.

A análise do código-fonte também revelou o uso de pixels de rastreamento, uma técnica frequentemente utilizada por spammers para monitorar quais usuários abriram a mensagem, confirmando contas ativas e aumentando a eficiência de campanhas maliciosas futuras. O mascaramento de links reforça ainda mais o risco, já que o destinatário acredita estar acessando informações legítimas de rastreamento, quando na realidade pode ser redirecionado para páginas fraudulentas, coleta de credenciais ou distribuição de malware.

Este caso evidencia a importância de analisar cuidadosamente remetentes, links e comportamentos suspeitos em mensagens de e-mail, além de demonstrar como mecanismos de segurança implementados por provedores, como o bloqueio automático de imagens e links, desempenham um papel fundamental na proteção dos usuários contra ameaças de phishing.



Autor: Paulo Cesar
Formado em Segurança da informação
[linkedin.com/in/paulo-cesar-security](https://www.linkedin.com/in/paulo-cesar-security)